

yxsona.com 支付与六平台授权开通指南

面向第一次接入的产品、运营和开发同学。本文按项目当前代码和部署配置编写，更新时间：2026-09-11。

先看结论

本项目的六个平台是：京东、淘宝、天猫、拼多多、小红书、抖音。项目已经预留 OAuth、商品同步、发布状态查询和支付网关接口，但仓库里的默认配置并不代表已经开通：

项目	当前代码事实	上线前必须补齐
支付宝/微信支付	本地 .env.example 是 PAYMENT_MODE=fixtrue；生产设计为独立支付网关	真实商户号、支付产品、网关 API、签名回调、查询、退款、对账证据
六平台授权	六个平台开关默认都是 false，CONNECTOR_FIXTURE_MODE=false	各平台企业开发者资质、应用、权限、回调、商家 OAuth 授权和读写验收
模型	所有模型流量必须走 HTTPS 中转	中转地址、密钥、允许域名、用量/成本回执和限额
文件	生产要求远程对象存储、TLS、KMS、病毒扫描	Bucket、KMS、版本控制、扫描 worker、扫描回执证据
上线门禁	README 和 release preflight 要求真实证据	生产配置、能力、支付、模型、对象存储、恢复和容量证据

因此，当前不能把页面上显示的“已连接”或占位 URL 当作真实开通证明。你已经具备公司主体、对公账户和 yxsona.com 域名，接下来重点是完成各平台申请、支付网关配置和真实验收。

一、已具备条件与还需准备

你已具备：

- 公司主体及营业执照；
- 对公银行账户；
- yxsona.com 域名。

还需要准备：

1. 各平台管理员账号、企业邮箱、手机号和二次验证；不要使用个人账号替代企业主体。
2. 产品名称、官网介绍、隐私政策、用户协议和客服联系方式，供平台审核填写。
3. 测试商家账号、测试商品、测试图片和一个可撤销的测试订单。
4. 云厂商 KMS、对象存储、日志和告警权限。

二、已完成的域名与待登记回调

1. DNS 和 HTTPS

以下基础设施已完成：

- yxsona.com 域名已具备；

- DNS 已配置到生产入口；
- HTTPS/TLS 证书已签发并生效；
- 运营后台域名和 OIDC 鉴权边界已配置。

因此这里不再列为申请或配置待办。上线前仍建议保留一次健康检查记录，作为发布证据：

上线前检查：

```
curl -I https://yxsona.com/healthz
curl -I https://yxsona.com/v1/healthz
```

检查结果应记录到对应发布证据中。后续第三方平台只填写下面列出的 yxsona.com HTTPS 回调地址，不能填本机地址、example.com 或内部 Service 地址。

2. 必须登记的 OAuth 回调地址

项目支持统一模板。六个平台分别登记以下精确地址，不能多一个斜杠，也不要把支付回调地址当 OAuth 地址：

```
https://yxsona.com/v1/oauth/callback/jd
https://yxsona.com/v1/oauth/callback/taobao
https://yxsona.com/v1/oauth/callback/tmall
https://yxsona.com/v1/oauth/callback/pinduoduo
https://yxsona.com/v1/oauth/callback/xiaohongshu
https://yxsona.com/v1/oauth/callback/douyin
```

3. 必须登记的支付回调地址

项目 API 对外接收的是：

```
https://yxsona.com/v1/billing/callback/alipay
https://yxsona.com/v1/billing/callback/wechat
```

订阅类支付另有 `/v1/subscriptions/callback/{channel}`。支付宝或微信的原生签名、证书和私钥放在独立支付网关；本服务只接收网关发来的、带 HMAC 签名的标准化回调，不把原生私钥放进浏览器、ConfigMap 或 Git。

三、开通支付宝支付

官方入口：[支付宝开放平台](#)。如果是给多个商家提供 SaaS，通常要评估“第三方应用/服务商”路径；只给自家公司使用时可评估“自用型应用”。最终以支付宝对主体和业务的审核结果为准。

A. 在支付宝完成申请

1. 用企业支付宝账号登录并完成企业认证。
2. 在开放平台创建应用，填写应用名称、图标、主体、官网和产品说明。
3. 选择实际使用的产品：PC 网站支付、当面付、手机网站支付等。不要为了“先开通”勾选项目不会使用的产品。
4. 配置应用网关/授权回调（若该产品要求），登记 <https://yxsona.com> 及实际回调地址。
5. 按支付宝要求生成并上传应用公钥或证书；应用私钥只进支付网关的 Secret Manager。
6. 提交审核，审核通过后发布应用。沙箱测试通过不等于生产开通。
7. 若服务多个商家，让每个商家在支付宝侧完成商家授权/签约；不要保存商家登录密码。

参考：[支付宝应用接入流程](#)、[支付宝网站/移动应用](#)、[支付宝支付服务商](#)。

B. 交给项目配置的内容

支付网关至少提供以下信息：

- 网关 HTTPS 地址：checkout、query、refund；
- 网关商户标识 `PAYMENT_PROVIDER_MERCHANT_ID`；
- 服务间 API Key；
- 网关回调 HMAC 密钥；
- 回调标准：订单号、支付宝交易号、金额（分）、币种、状态、时间戳、nonce、签名。

项目配置示例（值用 Secret Manager 注入）：

```
PAYMENT_MODE=provider
PAYMENT_CALLBACK_BASE_URL=https://yxsona.com/v1
PAYMENT_PROVIDER_CHECKOUT_API_URL=https://payments.your-company.com/v1/checkout
PAYMENT_PROVIDER_QUERY_API_URL=https://payments.your-company.com/v1/query
PAYMENT_PROVIDER_REFUND_API_URL=https://payments.your-company.com/v1/refund
PAYMENT_PROVIDER_MERCHANT_ID=<gateway-merchant-id>
PAYMENT_PROVIDER_API_KEY=<secret-manager-ref>
PAYMENT_EVIDENCE_PATH=<immutable-release-evidence-path>
```

四、开通微信支付

官方入口：[微信支付申请指引](#)。如果平台替多个商家收款，要先判断使用“普通商户”还是“服务商/特约商户”模式，不能直接把自有商户号复制给所有商家。

A. 在微信支付完成申请

1. 用企业主体申请微信支付商户号并完成商户认证、结算账户和经营类目审核。
2. 按真实场景开通产品。PC 网页通常重点评估 Native/扫码支付；H5、公众号 JSAPI、小程序支付需要额外的 AppID、授权域名或支付目录。
3. 在商户平台配置 API v3 密钥、商户证书、证书序列号；证书私钥和 API v3 密钥只放支付网关。
4. 配置支付结果通知 URL，使用 <https://yxsona.com/v1/billing/callback/wechat>，并按微信规则配置支付域名/业务域名。
5. 在沙箱或小额生产订单中验证下单、通知验签、订单查询、关闭/退款和重复通知幂等。
6. 若走服务商模式，分别完成服务商、特约商户和授权关系的审核，并保存授权关系证据。

参考：[微信支付合作伙伴支付](#)、[JSAPI 接入准备](#)、[小程序 JSAPI 申请](#)。

B. 项目侧支付规则

浏览器不能直接拿支付宝私钥、微信商户证书或 API v3 密钥。API 只调用内部支付网关；支付成功也只能在收到并验过签的回调、或查询到已支付后入账。超时、签名失败、金额不一致、重复 nonce 必须保持未知/失败状态，不能向商家展示“已支付”。

五、六个平台授权开通

总体流程（六个平台都一样）

1. 在官方开放平台注册企业开发者并完成主体认证。
2. 创建应用，申请“读取商品/库存”和需要的写权限；第一阶段只开读权限。
3. 填入对应精确 OAuth 回调地址，保存 App Key/Client ID 和 Secret。

- 配好项目的 API Base URL、OAuth authorize/token URL 和平台 API 路径。
- 将 Secret 写入 Vault/Secret Manager；数据库只保存 token 引用、过期时间和平台账号标识。
- 商家在 yxsona 的“连接平台”流程中点击官方授权，完成授权后回到回调页。
- 先做读商品/读库存，再做图片上传、草稿创建、发布和状态查询 canary；未通过证据门禁前保持写开关关闭。

平台	官方入口	代码配置前缀	首批必须拿到
京东	京东开放平台 / ISV 管理	JD_*	应用、App Key/Secret、商家授权、回调、商品读权限
淘宝	淘宝开放平台	TAOBAO_*	应用、App Key/Secret、OAuth 回调、商家授权、商品读权限
天猫	阿里开放平台	TMALL_*	独立应用/权限、Client ID/Secret、回调、刷新/撤销地址、商家授权
拼多多	拼多多开放平台	PDD_*	开发者认证、应用/服务、App Key/Secret、商家授权、回调
小红书	小红书开放平台	XHS_*	工具/自用应用审核、Client ID/Secret、回调、商品和媒体权限
抖音	抖音开放平台	DOUYIN_*	企业/组织认证、应用类型、Client Key/Secret、WEB 回调、所需权限

京东

在京东开放平台注册开发者，创建应用，填写回调 URL，申请接口权限；如果是 ISV，需要发起商家授权，由商家确认后取得授权码。项目预留 `JD_OAUTH_AUTHORIZE_URL`、`JD_OAUTH_TOKEN_URL`、`JD_API_BASE_URL` 以及 `/products`、`/products/create`、`/products/update`、`/publish/status` 路径。京东开放平台页面可能正在迁移，若旧 `opendj.jd.com` 被引导到新门户，以当前官方页面为准。

淘宝与天猫

两者常共用阿里开放平台入口，但在本项目中是两个独立连接器：不要把淘宝 token 填到天猫配置。淘宝按官方 OAuth 文档创建应用、配置回调和权限；天猫需单独确认应用类型、店铺授权范围、刷新/撤销接口和 `TMALL_OAUTH_SCOPES`。淘宝使用 `TAOBAO_*`，天猫使用 `TMALL_*`。

拼多多

在拼多多开放平台注册企业开发者，完成开发者认证，创建应用或服务，申请商品、库存、订单等权限，并让商家完成授权。先用测试店铺验证 token 换取、商品读取和状态查询，再申请/开启写权限。

小红书

在小红书开放平台走“立即加入/开发者”入口，按工具类或自用应用提交审核。ERP、商品上传等能力通常要按具体文档申请，不要只拿到 Client ID 就认为“商品发布可用”。项目对小红书保留了大量 JSON 字段映射（商品、SKU、图片、状态、请求 ID 等）；必须根据官方真实响应样例审核 `XHS_*_PATH`，不能猜路径。

抖音

在抖音开放平台登录，绑定邮箱，申请组织和开发者类型（自研或系统服务商），上传营业执照和盖章申请材料。个人主体能力受限，不能假设可以申请完整商品/发布权限。创建应用后取得 Client Key/Secret，使用服务端 WEB OAuth 回调；Client Secret 不得暴露到前端。项目需要根据真实 API 响应审核 `DOUYIN_*_PATH` 字段映射，并完成媒体上传和发布 canary。

六、项目配置怎么填

先复制 `.env.example` 到目标环境的 Secret Manager 模板，不要把生产值写回仓库。非敏感配置可进入 ConfigMap；以下字段必须进 Secret Manager：

- 支付网关 API Key、回调 HMAC Secret；
- 六个平台的 App Secret/Client Secret、refresh token 或 token 加密材料；
- `VAULT_TOKEN`、数据库、Redis、worker token/signing secret；
- `MODEL_RELAY_API_KEY`、OIDC 签名密钥、对象存储 KMS 相关密钥。

生产启用顺序建议如下：

```
JD_AUTH_ENABLED=true
JD_READ_ENABLED=true
JD_WRITE_ENABLED=false
# 其余五个平台按同样规则逐个平台启用
CONNECTOR_FIXTURE_MODE=false
PLUGIN_WRITE_ENABLED=false
MERCHANT_MCP_WRITE_ENABLED=false
```

每个平台先只开 `AUTH_ENABLED` 和 `READ_ENABLED`。读商品、读库存、token 刷新、撤销和审计证据齐全后，再按平台单独开启 `WRITE_ENABLED`，不要一次性全开。

Vault 路径可按项目的 `VAULT_CREDENTIAL_PATH_PREFIX=merchant-marketing` 组织，例如：

```
secret/merchant-marketing/payment/provider-api-key
secret/merchant-marketing/payment/callback-secret
secret/merchant-marketing/platform/jd/app-secret
secret/merchant-marketing/platform/taobao/app-secret
secret/merchant-marketing/platform/tmall/client-secret
secret/merchant-marketing/platform/pdd/app-secret
secret/merchant-marketing/platform/xhs/client-secret
secret/merchant-marketing/platform/douyin/client-secret
```

真实路径以部署 Secret Manager

的命名规范为准；不要在文档、日志、截图、工单中粘贴密钥、证书私钥、授权码或完整 token。

七、还必须配置的第三方服务

除了支付和六平台，本项目生产还依赖：

1. 模型中转：`MODEL_RELAY_BASE_URL`、API Key、允许的精确 host、文本/OCR/图片/视频模型、RPM/TPM/日成本上限、真实用量和成本回执。中转缺配置时必须阻断，不允许静默调用直连厂商。
2. 数据库与 Redis：生产连接串、RLS/租户隔离、迁移 owner、备份和恢复演练；API/worker 不使用迁移高权限账号。
3. 对象存储与 KMS：Bucket、Region、TLS Endpoint、KMS Key、版本控制、生命周期策略、签名下载 URL。
4. 病毒扫描 worker：ClamAV 或批准的扫描服务、服务身份、最低病毒库版本、签名扫描回执；缺失时素材应留在 quarantine。

5. OIDC/运营后台：ops.yxsona.com 的身份提供商、回调、代理签名密钥、管理员角色和审计日志。
6. 告警、日志、链路追踪：支付回调失败、OAuth 过期、token 刷新失败、平台限流、模型成本超限、扫描失败都要可告警。
7. 规则与平台能力清单：若使用远程平台规则 manifest，必须有 HTTPS 地址、签名密钥、版本和审核记录。
8. 备份与恢复：数据库、Vault、对象存储和发布证据的备份策略；至少完成一次带结果的恢复演练。

八、验收清单：完成这些才算开通

支付宝/微信

- [] 企业商户号、结算账户和对应支付产品审核通过。
- [] yxsona.com HTTPS 可访问，支付通知 URL 已登记。
- [] checkout/query/refund 三个网关接口均为 HTTPS，并能返回可追踪 request ID。
- [] 正常支付、重复回调、金额不一致、签名错误、超时查询、退款均有测试记录。
- [] 回调 timestamp、nonce、HMAC、渠道、订单、金额和币种均验证；重复 nonce 不能二次入账。
- [] `PAYMENT_EVIDENCE_PATH` 指向不可变的发布证据；未有证据时保持 NO-GO。

六个平台

- [] 每个平台企业开发者认证、应用审核和权限清单有截图/导出记录。
- [] 六个 OAuth 回调 URL 精确匹配，state 与 workspace 绑定且一次性使用。
- [] 每个平台至少完成一次商家授权、token 刷新和撤销。
- [] 读商品/库存成功；图片上传、草稿、发布、状态查询分别有 request ID 和结果。
- [] 平台错误、限流、权限不足和过期 token 有可读提示，不显示 UNKNOWN 作为最终业务结论。
- [] 写权限逐个平台 canary，通过后才打开对应 `*_WRITE_ENABLED`。

发布门禁

所有真实证据都绑定版本、环境、workspace、时间和 request ID。证据缺失时，正确状态是“未开通/阻断”，不是用 fixture 数据补齐。当前仓库默认值仍是本地支付 fixture、六平台开关关闭、模型/存储/扫描等生产证据待补，因此在这些证据准备前不要宣布生产可用。

常见问题

为什么拿到了 App Secret 还是不能同步？OAuth 应用只是第一步，还需要商家授权、接口权限、正确 API 路径、token 存储、真实响应映射和 canary。

淘宝授权后能不能直接当作天猫授权？不能。项目连接器和凭据字段分开，权限和店铺授权也应分别确认。

能不能把支付宝/微信私钥放到 API 的环境变量？本项目设计不允许。原生支付密钥放独立支付网关，API 只持有网关访问凭据和回调密钥引用。

沙箱通过是不是就能上线？不是。还要完成生产主体审核、真实小额订单、回调验签、对账、退款和不可变证据。

谁来操作商家授权？商家在 [yxsona](https://yxsona.com) 的连接流程中跳转到官方授权页并确认；系统保存授权结果和凭据引用，不保存平台密码。

官方入口汇总

- 支付宝：[开放平台](#) · [接入流程](#)
- 微信支付：[申请指引](#) · [合作伙伴支付](#)
- 京东：[开发者中心](#) · [ISV 管理](#)
- 淘宝/天猫：[阿里开放平台](#) · [OAuth 文档](#)
- 拼多多：[开放平台](#)
- 小红书：[开放平台](#)
- 抖音：[开放平台](#) · [接入指南](#)